API SECURITY RISK ANALYSIS REPORT

CYBER SECURITY TASK 3(FUTURE INTERNS)

PREPARED BY TINASHE NYAKUMBI

This report presents a security analysis of a public API to identify potential risks and recommend improvements.

1. API Tested

API Name: JSONPlaceholder API
Base URL: https://jsonplaceholder.typicode.com
Endpoints Tested:

- /users
- /posts

---

2. Methodology

- *Tools Used*: Web Browser (Chrome) / Postman (optional)
- *Testing Method*: Read-only API testing
- *Scope:* Public API endpoints only
- *Approach*:
    - Accessed endpoints directly
    - Inspected response data
    - Evaluated authentication and access control
    - Identified potential security risks

---

3. Observation

Endpoint: /users

The API response contains:

- User names
- Email addresses
- Phone numbers

- Full addresses (city, street, zip code)

Endpoint: /posts

The API response contains:

- Post titles
- Post content (body)
- User IDs

Both endpoints are publicly accessible without authentication.

---

4. Security Findings

1. No Authentication (HIGH)

Observation:
The API endpoints are accessible directly without any login or authentication mechanism.

Risk:
Unauthorized users can access sensitive data without restriction.

Business Impact:

- Data privacy violations
- Unauthorized data scraping
- Potential compliance issues

Remediation:

- Implement authentication mechanisms such as API keys, OAuth, or JWT tokens

---

2. Excessive Data Exposure (MEDIUM)

Observation:
The /users endpoint exposes sensitive user information including email, phone number, and address.

Risk:
More data is exposed than necessary.

Business Impact:

- Increased risk of phishing and spam
- Potential misuse of personal information

Remediation:

- Limit API responses to only required fields
- Implement data filtering and masking

---

3. No Rate Limiting (MEDIUM)

Observation:
Unlimited requests can be sent to the API endpoints.

Risk:
Attackers can overload the system with repeated requests.

Business Impact:

- Server performance degradation
- Potential Denial of Service (DoS) scenarios

Remediation:

- Implement rate limiting (e.g., 100 requests per minute per user)

---

4. Lack of Access Control (LOW)

Observation:
All data is accessible to any user without restrictions.

Risk:
No differentiation between authorized and unauthorized users.

Business Impact:

- Unauthorized access to data
- Weak data protection

Remediation:

- Implement role-based access control (RBAC)
- Restrict access based on user roles

---

5. Predictable Data Structure (LOW)

Observation:
User IDs and Post IDs are sequential and predictable.

Risk:
Attackers can easily enumerate all records.

Business Impact:

- Bulk data extraction
- Increased exposure of system data

Remediation:

- Use non-sequential identifiers (UUIDs)
- Apply access restrictions on data retrieval

---

5. Additional Endpoint Analysis

Endpoint: /posts

The /posts endpoint confirms similar security issues:

- No authentication required
- No rate limiting

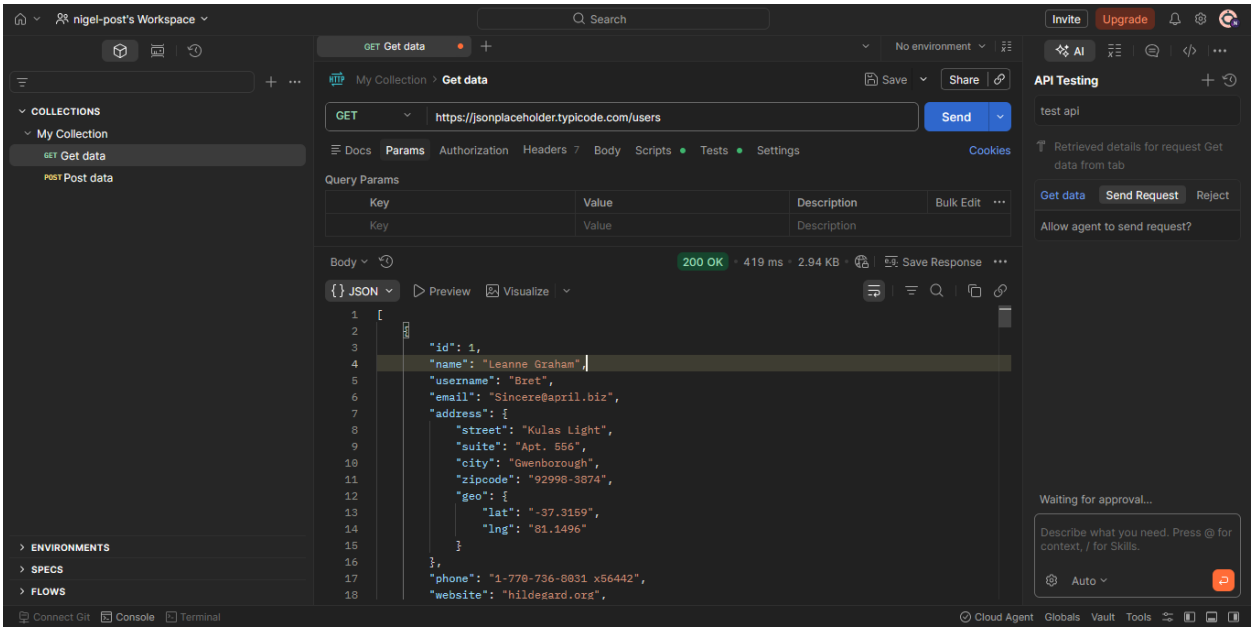
- Public access to all content

This reinforces that the API lacks fundamental security controls across multiple endpoints.

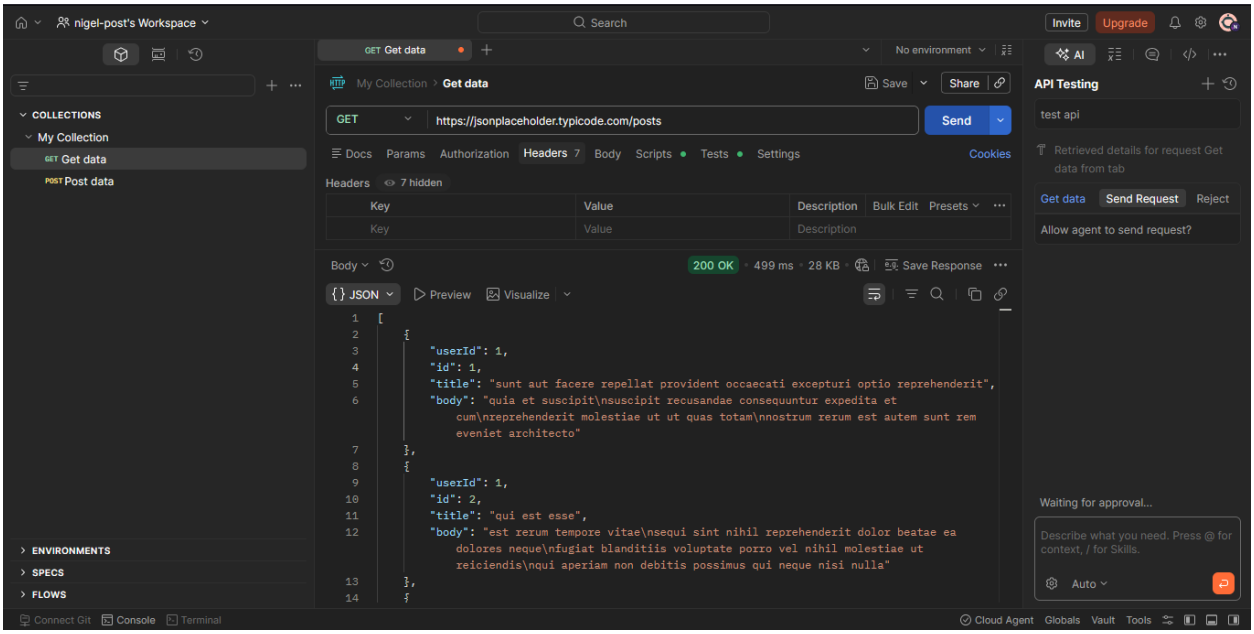
---

6. Screenshots

- ***Figure 1:*** *API response from /users endpoint*



- ***Figure 2:*** *API response from /posts endpoint*



---

7. Conclusion

The JSONPlaceholder API demonstrates several key security weaknesses, including lack of authentication, excessive data exposure, and absence of rate limiting.

While the API is intended for testing purposes, these issues represent critical vulnerabilities if present in a real-world production system.

Implementing authentication mechanisms, restricting data exposure, enforcing rate limits, and improving access control would significantly enhance the overall security posture of the API.

---

8. Tools Used

- Postman
- JSONPlaceholder API